

IT Security Policy

Owning area: IT

Policy owner: Director of Information Security

Document ID: ITS-POL-001

Version: 4.0

Last reviewed: August 2026

Next scheduled review: August 2027

1. Purpose and Overview

This policy defines the minimum security requirements for IronStore's information systems, devices, applications, and data. IronStore operates across Europe and processes customer, employee, supplier, payment, and operational information. Security controls must protect confidentiality, integrity, availability, and legal compliance.

The policy supports IronStore's obligations under applicable European data protection and cybersecurity requirements, including the General Data Protection Regulation (GDPR), the NIS2 Directive where applicable, and local employment and regulatory requirements. It applies a risk-based approach: higher-risk systems and data require stronger controls, closer monitoring, and more frequent review.

All employees, contractors, temporary workers, and third parties with access to IronStore resources must comply with this policy. Failure to comply may result in access removal, disciplinary action, contract termination, or legal action.

2. Scope

This policy applies to:

- IronStore corporate offices, warehouses, fulfilment sites, and remote working environments.
- Company-managed laptops, mobile devices, servers, network equipment, and storage.
- Cloud services, including Microsoft 365, Azure, Shopify Plus, Salesforce, Jira, and Snowflake.
- Customer, employee, supplier, financial, payment, product, and operational data.
- Employees, contractors, agency workers, service providers, and approved business partners.
- Systems developed, operated, or procured by IronStore, including mobile applications and e-commerce platforms.

Personal devices may access IronStore systems only through an approved Bring Your Own Device (BYOD) arrangement and must meet the requirements in the Device Standard.

3. Policy Statement and Procedures

3.1 Information Classification

Information owners must classify data when it is created or received. The following classifications apply:

- **Public:** Approved for unrestricted external release, such as published product descriptions.
- **Internal:** Routine business information intended for IronStore personnel.
- **Confidential:** Information that could cause material harm if disclosed, including contracts, pricing plans, source code, and supplier terms.
- **Restricted:** Highly sensitive information requiring enhanced controls, including payment-related data, identity documents, authentication secrets, health information, and unmasked customer records.

Requirements:

- Restricted data must be encrypted in transit and at rest.
- Confidential and Restricted data must not be sent to personal email, consumer file-sharing services, or unapproved AI or productivity tools.
- Access must be granted on a least-privilege and need-to-know basis.
- Data owners must review access to Restricted repositories at least quarterly.
- Suspected loss or unauthorised disclosure must be reported to the Security Operations mailbox immediately.

3.2 Identity and Access Management

IronStore uses Microsoft Entra ID as the primary identity provider and requires centralised authentication wherever technically possible.

- Each individual must use a unique IronStore account. Shared accounts are prohibited unless approved by Information Security.
- Multi-factor authentication (MFA) is mandatory for Microsoft 365, VPN, cloud consoles, administrative tools, and production systems.
- Phishing-resistant MFA, such as FIDO2 security keys or passkeys, is required for privileged administrators and payment-platform administrators.
- Access requests must be approved by the user's line manager and the relevant system owner.
- Privileged access requires an additional approval from the IT Security Manager.
- Access must be removed within four hours of a confirmed termination and by the end of the worker's last day for planned departures.
- Role changes must trigger an access review within five business days.
- Dormant accounts are disabled after 45 days unless the system owner documents a business reason.
- Passwords must be unique, stored only in the approved password manager, and never shared through chat or email.
- Service accounts must have a named owner, documented purpose, restricted permissions, and secrets rotated at least every 180 days.

Quarterly, system owners must certify access to critical systems, including the order management platform, warehouse management system, ERP, customer service platform, and payment administration consoles.

3.3 Endpoint and Mobile Security

All company-managed endpoints must be enrolled in Microsoft Intune and protected by Microsoft Defender for Endpoint.

Minimum requirements include:

- Automatic operating system and application updates.
- Full-disk encryption using BitLocker or an approved equivalent.
- Screen lock after a maximum of 10 minutes of inactivity.
- Endpoint detection and response enabled and reporting to the Security Operations Centre (SOC).
- Local administrator rights removed unless a documented exception is approved.
- Approved endpoint firewall and anti-malware controls enabled.
- Corporate data stored only in approved locations, such as OneDrive, SharePoint, or managed application storage.

Lost or stolen devices must be reported to the Service Desk within one hour of discovery. IT may remotely lock or wipe the device. Employees must not disable security software, install unapproved software, or connect unknown USB devices to company equipment.

Remote work must use a private, access-controlled network. Public Wi-Fi may be used only with the IronStore VPN or an approved zero-trust connection. Confidential discussions must not take place where unauthorised people can overhear them.

3.4 Network, Cloud, and Application Security

The Infrastructure team must maintain separate development, test, and production environments. Production access must be restricted, logged, and reviewed.

- Internet-facing services must be protected by approved web application firewall and distributed denial-of-service controls.
- Administrative interfaces must not be directly exposed to the public internet.
- Network security groups and firewall rules require documented owners and annual review.
- Critical cloud services must use central logging, MFA, encryption, and region-appropriate data residency settings.
- Production secrets must be stored in Azure Key Vault or another approved secrets-management service.
- Customer payment data must be processed through approved payment service providers. IronStore systems must not store full card numbers or CVV data.
- Source code must be stored in IronStore GitHub Enterprise repositories with branch protection and mandatory peer review.
- High-risk code changes require security review before production deployment.
- Vulnerability scanning must run at least weekly for internet-facing assets and before major releases.

Development teams must use synthetic or masked data in non-production environments. Production data may be copied to test systems only with written approval from the system owner, Data Protection Officer, and Security Architecture lead.

3.5 Vulnerability and Patch Management

IT Security maintains the central asset and vulnerability register. Asset owners are responsible for remediation within these limits:

- Critical vulnerabilities with known exploitation: mitigation within 24 hours and remediation within seven days.
- Other Critical vulnerabilities: remediation within 14 days.
- High vulnerabilities: remediation within 30 days.
- Medium vulnerabilities: remediation within 90 days.
- Low vulnerabilities: address during normal maintenance planning.

Where remediation is not possible, the owner must document compensating controls, business impact, and a target date. Exceptions require approval from the Director of Information Security and expire after 90 days unless renewed.

Unsupported operating systems, applications, and network devices must not be used in production unless an approved exception and replacement plan exist.

3.6 Logging, Monitoring, and Security Events

Security-relevant events must be recorded centrally in Microsoft Sentinel or an approved equivalent. Critical systems must log authentication, privilege changes, configuration changes, administrative actions, and data export events.

- Logs must use synchronised time sources.
- Security logs must be retained for at least 12 months, subject to legal and privacy requirements.
- Restricted-data access logs must be protected from alteration.
- The SOC monitors alerts during business hours and maintains an on-call escalation rota for critical events.
- High-severity alerts must be triaged within 30 minutes.
- Log access is limited to authorised IT Security personnel and approved investigators.

Employees must report suspected phishing, malware, unauthorised access, data loss, or unusual system behaviour through the Service Desk portal, the “Report Phishing” button, or the 24-hour security contact number listed on the intranet. They must not investigate beyond basic safe actions or delete evidence.

3.7 Incident Response

The Incident Response Plan defines the response process. All suspected incidents are recorded in ServiceNow with a severity, owner, timeline, and affected assets.

Response stages are:

1. **Identify and contain:** Confirm the event, isolate affected accounts or devices, and preserve evidence.
2. **Assess:** Determine affected systems, data, jurisdictions, and business impact.
3. **Eradicate and recover:** Remove the cause, restore services, and validate system security.

4. Notify and review: Inform management, Legal, Privacy, insurers, regulators, customers, or law enforcement where required.

Potential personal data breaches must be reported to the Data Protection Officer immediately and no later than two hours after discovery. The DPO determines whether regulatory notification is required. Employees must not contact regulators, customers, or media about a security incident unless authorised.

A post-incident review must be completed within ten business days for High and Critical incidents. Actions are tracked to closure by the Security Governance team.

3.8 Backup, Continuity, and Recovery

Critical business services, including checkout, order management, fulfilment, customer service, ERP, and identity services, must have documented recovery requirements.

- Critical production data must be backed up daily, with more frequent replication where defined by the service owner.
- Backups must be encrypted, access-controlled, and protected against deletion or ransomware.
- At least one backup copy must be logically or physically separated from the production environment.
- Restore tests must be completed quarterly for Tier 1 systems and annually for other critical systems.
- Recovery results and unresolved gaps must be reported to the IT Risk Committee.

Business owners must maintain manual workarounds for essential fulfilment, customer support, and payment reconciliation activities.

3.9 Third-Party Security

Procurement and the system owner must complete a security and privacy assessment before a supplier receives Confidential or Restricted data or connects to IronStore systems.

Contracts must address:

- Security controls and incident notification.
- Data processing responsibilities and sub-processors.
- Access limitation and authentication.
- Data location, retention, deletion, and return.
- Audit rights or equivalent assurance reports.
- Exit arrangements and secure transfer of data.

Critical suppliers are reviewed annually. Supplier access must be time-limited, individually assigned, MFA-protected, and removed when the engagement ends.

3.10 Security Awareness

All personnel must complete security and privacy training within 30 days of joining IronStore and annually thereafter. Additional training is required for developers, privileged administrators, warehouse technology users, customer

service teams, and personnel handling Restricted data.

IronStore may conduct simulated phishing exercises. Personnel who fail a simulation may be assigned targeted training. Repeated unsafe behaviour is escalated to the individual's manager.

4. Roles and Responsibilities

- **Board and Executive Committee:** Set risk appetite and receive material security reporting.
- **Director of Information Security:** Own this policy, approve security standards, and escalate significant risks.
- **Security Operations Centre:** Monitor alerts, coordinate incident response, and maintain security tooling.
- **IT Infrastructure:** Operate identity, endpoint, network, backup, and cloud controls.
- **System and Data Owners:** Approve access, classify information, manage risks, and maintain recovery requirements.
- **Data Protection Officer:** Advise on GDPR, breach assessment, data subject rights, and privacy impact assessments.
- **Procurement and Legal:** Ensure supplier contracts include appropriate security and privacy terms.
- **Managers:** Confirm staff access, training, and compliance for their teams.
- **All personnel:** Protect credentials, follow procedures, and report security concerns promptly.

5. Related Documents and References

- ITS-STD-002: Identity and Access Management Standard
- ITS-STD-003: Endpoint and Mobile Device Standard
- ITS-STD-004: Vulnerability and Patch Management Standard
- ITS-PRC-001: Incident Response Plan
- ITS-PRC-002: Change and Release Management Procedure
- ITS-PRC-003: Backup and Recovery Procedure
- DPO-STD-001: Data Classification and Retention Standard
- Third-Party Risk Management Procedure
- GDPR and applicable national data protection legislation
- NIS2 Directive and applicable national implementing legislation

6. Revision History

- **Version 4.0 — August 2026:** Added phishing-resistant MFA requirements, cloud logging controls, supplier review intervals, and updated vulnerability deadlines.
- **Version 3.2 — August 2025:** Expanded remote-working, backup testing, and personal data breach escalation requirements.
- **Version 3.0 — July 2024:** Consolidated endpoint, access management, and incident response requirements into the enterprise policy.